

星云科技集团网络安全等级保护合规自查报告

报告年度：2025 | 报告类型：年度自查 | 密级：内部

一、报告概述

根据《信息安全等级保护管理办法》及 GB/T 22239-2019 要求，星云科技集团信息安全部于 2025 年 6 月至 7 月组织开展了年度网络安全等级保护合规自查。本次自查覆盖集团12个等保三级系统、8 个等保二级系统，采用「文档审查 + 技术检测 + 人员访谈」相结合的方式，形成本报告。

二、自查范围

序号	系统名称	等级级别	备案号	上次测评
1	星云OA办公系统	三级	33010613001-22001	2024-11
2	星云ERP财务系统	三级	33010613001-22002	2024-10
3	星云CRM客户系统	三级	33010613001-22003	2025-01
4	星云eHR人事系统	三级	33010613001-22004	2024-12
5	数据中台	三级	33010613001-22005	2025-02
6	统一身份认证IAM	三级	33010613001-22006	2024-09
7	安全运营中心SIEM	三级	33010613001-22007	2025-03
8	互联网保险核心系统	三级	33010613001-22008	2024-08

三、安全技术体系自查结果

控制域	检查项	符合	部分符合	不符合
安全物理环境	机房访问控制、防火防水	4	1	0
安全通信网络	边界防护、访问控制、入侵防范	6	2	0
安全区域边界	WAF、防火墙策略、日志审计	5	1	1
安全计算环境	身份鉴别、访问控制、安全审计	12	3	1
安全管理中心	集中管控、日志汇聚、告警	4	2	0
安全管理制度	制度体系、评审修订、培训	8	1	0
安全管理机构	组织架构、人员配备、审批	5	0	0
安全管理人员	录用离岗、考核培训、保密	6	1	0
安全建设管理	定级备案、方案设计、测试验收	7	2	0
安全运维管理	变更管理、备份恢复、应急预案	9	2	1

四、主要差距与风险项

- 【中危】CRM 系统部分 API 接口未启用速率限制，存在暴力枚举风险；计划 2025-Q3 完成改造。
- 【中危】2 台遗留 Linux 服务器未安装 EDR 代理，已纳入资产清点专项，限期 2025-08-31 整改。

- 3. 【低危】部分三级系统日志留存为 90 天，未达到制度要求的 180 天；SIEM 扩容项目已立项。
- 4. 【低危】外包人员权限季度复核存在 2 个部门逾期；已发通报并纳入部门 KPI。
- 5. 【信息】零信任网关 MFA 覆盖率 94%，目标 100%，剩余为测试专用账号。

五、整改计划

编号	整改项	责任部门	完成时限	状态
R-01	CRM API 限流改造	研发效能部	2025-09-30	进行中
R-02	遗留服务器 EDR 覆盖	IT运维中心	2025-08-31	进行中
R-03	日志留存扩容至180天	信息安全部	2025-10-31	已立项
R-04	权限复核流程自动化	IT运维中心	2025-12-31	规划中
R-05	零信任MFA 100%覆盖	IT运维中心	2025-08-15	进行中

六、结论与建议

综合自查结果，星云科技集团等保三级系统整体符合率约 87.3%，较 2024 年度提升 4.2 个百分点。安全管理体系较为完善，主要差距集中在技术层面细粒度控制与运维自动化方面。

建议：

- 持续投入零信任架构建设，提升远程办公与多云环境下的统一管控能力；
- 推进权限复核与账号生命周期自动化，降低人工遗漏风险；
- 加强开发安全（DevSecOps）能力，将安全检测嵌入 CI/CD 流水线；
- 2025 年 Q4 邀请具有资质的测评机构开展正式等保测评。

编制：信息安全部 | 审核：CISO | 日期：2025年7月15日